Universidade Aberta

Licenciatura em Engenharia Informática

UC 21184 — Projeto de Engenharia Informática

ForensiQ

Plataforma Modular de Gestão de Prova Digital
para First Responders

Relatório Intercalar

Autor: João M. M. Rodrigues (Nº 2203474)

Orientador: Professor Pedro Duarte Pestana

Repositório: github.com/joao-pt/ForensiQ

Data: May 2, 2026

Documento produzido no âmbito do Projeto Final de Licenciatura

Universidade Aberta · Ano lectivo 2025/2026

Índice

1 Introdução **2**
1.1 Motivação . . . 2
1.2 Objectivos . . . 2

2 Análise de Requisitos **2**
2.1 Requisitos Funcionais . . . 2
2.2 Requisitos Não Funcionais . . . 3

3 Arquitectura do Sistema **3**
3.1 Visão Geral (C4 Nível 1 — Contexto) . . . 3
3.2 Diagrama de Containers (C4 Nível 2) . . . 4
3.3 Modelo de Dados . . . 4
3.4 Máquina de Estados — Cadeia de Custódia . . . 5
3.5 Fluxo Operacional — Criação de uma Evidência . . . 6
3.6 Decisões de Arquitectura (ADRs) . . . 6

4 Implementação **6**
4.1 Estado Actual de Desenvolvimento . . . 6
4.2 Backend . . . 7
4.2.1 Integridade e Imutabilidade . . . 7
4.3 Frontend . . . 7
4.4 Testes . . . 8

5 Calendário e Planeamento **8**
5.1 Progresso Face ao Plano Inicial . . . 8
5.2 Próximas Tarefas . . . 9

6 Considerações sobre Ética e Privacidade **9**

7 Conclusão **10**

1 Introdução

O presente relatório intercalar descreve o estado de desenvolvimento do projecto **ForensiQ**, uma plataforma web modular destinada à gestão da prova digital em contexto de cena de crime.

O projecto insere-se no âmbito da Unidade Curricular 21184 — Projeto de Engenharia Informática, da Licenciatura em Engenharia Informática da Universidade Aberta, com orientação do Professor Pedro Duarte Pestana.

1.1 Motivação

A gestão de prova digital em ambiente policial continua a depender, em larga medida, de suportes físicos — formulários em papel, registos manuscritos e cadeias de custódia em suporte analógico — sujeitos a degradação, perda e manipulação inadvertida. A experiência profissional do autor como perito de informática forense na Polícia de Segurança Pública (PSP) permitiu identificar, em primeira mão, as principais lacunas deste processo: ausência de timestamp imutável na apreensão de evidências, impossibilidade de verificar *post hoc* a integridade dos metadados registados, e falta de rastreabilidade da cadeia de custódia entre o campo e o laboratório.

A inexistência de um registo digital imutável e rastreável compromete a cadeia de custódia e, por consequência, a admissibilidade das provas em sede judicial. O ForensiQ surge como resposta directa a este problema, digitalizando e padronizando o processo desde o first responder até ao laboratório forense, em conformidade com a norma internacional ISO/IEC 27037:2012 para a preservação de prova digital.

1.2 Objectivos

O ForensiQ tem como objectivos principais:

1. Digitalizar e padronizar o registo de prova digital em cena de crime (recolha, metadados, fotografia, geolocalização);
2. Implementar uma cadeia de custódia imutável com integridade criptográfica (SHA-256, conforme ISO/IEC 27037);
3. Garantir a rastreabilidade completa desde o first responder até ao laboratório e tribunal;
4. Disponibilizar uma interface mobile-first, utilizável com luvas e em condições adversas de iluminação.

2 Análise de Requisitos

2.1 Requisitos Funcionais

RF	Descrição	Prior.	Estado
RF01	Autenticação com JWT e controlo de acesso por perfil (Agente / Perito)	Alta	Implementado
RF02	Registo de ocorrência com metadados GPS e timestamp (NTP-synced)	Alta	Implementado

RF	Descrição	Prior.	Estado
RF03	Registo de evidência com fotografia e hash SHA-256 (ISO/IEC 27037)	Alta	Implementado
RF04	Cadeia de custódia append-only com máquina de estados (7 estados)	Alta	Implementado
RF05	Módulo de dispositivos digitais (tipo, marca, modelo, IMEI, condição)	Média	Implementado
RF06	API REST com ≥10 endpoints + Swagger UI	Alta	Implementado
RF07	Timeline visual da cadeia de custódia	Média	Implementado
RF08	Mapa interactivo de ocorrências (Leaflet.js)	Média	Implementado
RF09	Exportação de relatório de prova para PDF (ReportLab, ISO/IEC 27037)	Média	Implementado
RF10	Suporte HTTPS em produção	Alta	Implementado

Tabela 1: Requisitos funcionais do MVP ForensiQ

2.2 Requisitos Não Funcionais

RNF	Descrição	Prior.	Estado
RNF01	Interface mobile-first com touch targets ≥48px (WCAG 2.1 AA)	Alta	Implementado
RNF02	Imutabilidade dos registos de evidência e custódia (bloqueio de UPDATE/DELETE)	Alta	Implementado
RNF03	Integridade criptográfica (SHA-256 encadeado) conforme ISO/IEC 27037	Alta	Implementado
RNF04	Conformidade com RGPD (dados pessoais mínimos)	Alta	Parcial
RNF05	Cobertura de testes ≥80% das linhas de código	Média	Em avaliação

Tabela 2: Requisitos não funcionais do ForensiQ

3 Arquitectura do Sistema

3.1 Visão Geral (C4 Nível 1 — Contexto)

A Figura 1 apresenta o modelo de contexto C4 Nível 1 do sistema, identificando os actores externos e os sistemas com que o ForensiQ interage.

O ForensiQ é uma aplicação web com arquitectura cliente-servidor:

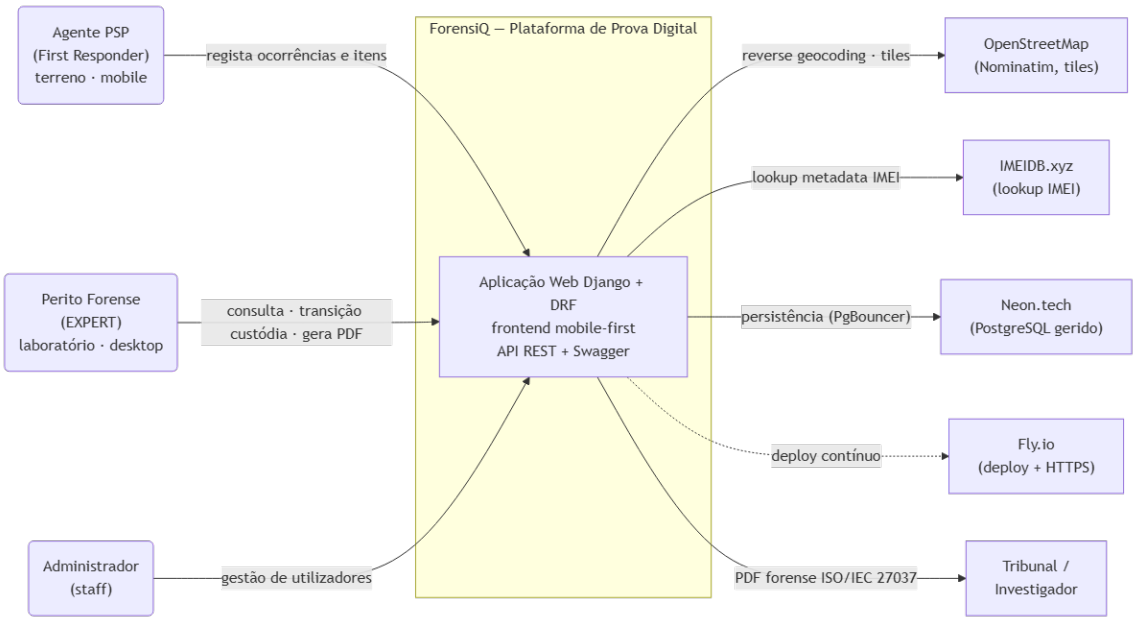

Figura 1: Diagrama C4 Nível 1 — Contexto do sistema ForensiQ.

- **Frontend:** HTML5/CSS3/JavaScript vanilla, mobile-first, servido pelo Django como templates estáticos;
- **Backend:** Django 5.2 + Django REST Framework, com autenticação JWT (SimpleJWT) e documentação automática via drf-spectacular;
- **Base de dados:** PostgreSQL hospedada no Neon.tech (serverless, connection pooling via PgBouncer);
- **Deployment:** Fly.io com HTTPS automático (Let's Encrypt);
- **Mapas:** Leaflet.js com tiles OpenStreetMap (sem chave API).

3.2 Diagrama de Containers (C4 Nível 2)

A Figura 2 detalha os componentes internos do sistema, separando frontend, API REST, camada de persistência e serviços externos.

3.3 Modelo de Dados

A Figura 3 apresenta o modelo entidade-relação com as entidades centrais da plataforma, suas chaves primárias e principais relações.

O modelo de dados centra-se em cinco entidades principais:

`User` Utilizador com perfil `AGENT` (first responder) ou `EXPERT` (perito forense digital);

`Occurrence` Ocorrência / cena de crime, com coordenadas GPS, timestamp e agente responsável;

`Evidence` Evidência apreendida, com fotografia, metadados GPS, hash SHA-256 e imutabilidade pós-registo;

`DigitalDevice` Dispositivo digital associado a uma evidência (tipo, marca, modelo, IMEI, condição);

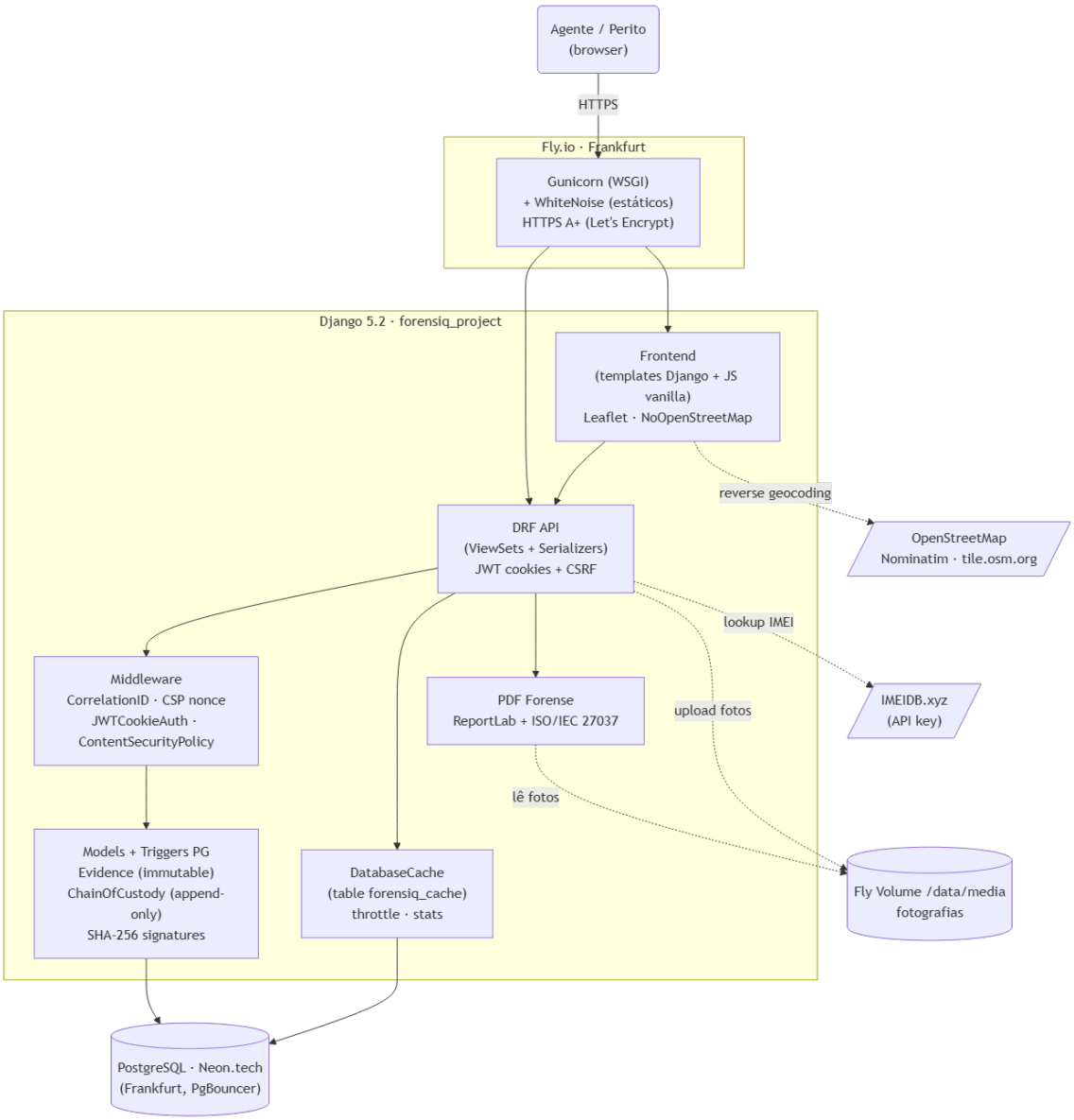

Figura 2: Diagrama C4 Nível 2 — Containers do ForensiQ.

`ChainOfCustody` Registo imutável (append-only) de transição na cadeia de custódia, com hash encadeado.

3.4 Máquina de Estados — Cadeia de Custódia

A cadeia de custódia segue uma máquina de estados com progressão linear e sem retrocesso, conforme as boas práticas forenses (Figura 4).

Cada transição é validada pelo backend antes de ser gravada, e cada registo inclui um hash SHA-256 encadeado com o registo anterior (estrutura blockchain-like). Triggers PL/pgSQL ao nível da base de dados (`prevent_evidence_modification`) bloqueiam fisicamente operações UPDATE/DELETE sobre `Evidence` e `ChainOfCustody`, garantindo a imutabilidade mesmo perante uma escrita directa fora do ORM.

3.5 Fluxo Operacional — Criação de uma Evidência

A Figura 5 resume o fluxo de criação de uma evidência por um agente no terreno. Os passos críticos para integridade forense (cálculo do hash, preservação de EXIF, validação do trigger) estão explicitamente identificados.

3.6 Decisões de Arquitectura (ADRs)

As principais decisões arquitecturais foram documentadas em *Architecture Decision Records* (ADRs) disponíveis em `docs/architecture/adr/`:

- ADR-0001: Utilização do Neon.tech como base de dados PostgreSQL;
- ADR-0002: Estrutura do projecto Django + modelos;
- ADR-0003: Design da API REST (DRF + ViewSets);
- ADR-0004: Arquitectura do frontend (HTML/CSS/JS vanilla);
- ADR-0005: Deployment no Fly.io.

4 Implementação

4.1 Estado Actual de Desenvolvimento

Componente	**Progresso**	**Notas**
Backend Django	∼95%	Modelos, API REST, permissões, PDF export, lookup IMEI/VIN, triggers PG de imutabilidade, JWT em cookies HttpOnly + CSRF
Frontend (templates)	∼90%	Login, dashboard, ocorrências, evidências, timeline custódia, mapa Leaflet, custody list, wizard 6 passos, tema dia/noite com auto-sunset
Testes automatizados	∼90%	169 testes (14 modelos + 96 API + 45 frontend + 14 PDF)
Deployment / DevOps	∼85%	Fly.io, HTTPS A+, HSTS preload, PostgreSQL Neon.tech, Dockerfile multi-stage, volume persistente
Exportação PDF	∼95%	Implementado e botão integrado: `/api/evidences/<id>/pdf/` (ReportLab)
Segurança	∼90%	CSP nonce script-src + style-src, OWASP top-10 limpo em Semgrep, RBAC, throttling, IDOR fechado
Documentação LaTeX	∼80%	Proposta + relatório intercalar com diagramas C4 e ER

Componente	Progresso	Notas

Tabela 3: Estado de desenvolvimento por componente.

4.2 Backend

O backend foi desenvolvido com **Django 5.2** e **Django REST Framework 3.15**. A estrutura do projecto segue as convenções Django:

- `forensiq_project/` — configuração global (settings, URLs raiz);
- `core/` — app principal com todos os modelos, serializers, views e testes.

A API REST disponibiliza os seguintes endpoints principais:

- `/api/auth/token/` — autenticação JWT (login);
- `/api/users/` — utilizadores (admin) e `/me/` (perfil próprio);
- `/api/occurrences/` — ocorrências (CRUD);
- `/api/evidences/` — evidências (criação e consulta);
- `/api/devices/` — dispositivos digitais;
- `/api/custody/` — cadeia de custódia (append-only);
- `/api/custody/evidence/<id>/timeline/` — timeline completa;
- `/api/evidences/<id>/pdf/` — relatório forense PDF (RF09);
- `/api/docs/` — Swagger UI (drf-spectacular).

4.2.1 Integridade e Imutabilidade

Em conformidade com a norma **ISO/IEC 27037:2012** (ISO/IEC, 2012), os registos de evidência e de cadeia de custódia são imutáveis após criação:

- O método `save()` de `Evidence` e `ChainOfCustody` lança `ValidationError` se `self.pk is not None` (bloqueio de UPDATE);
- O método `delete()` está igualmente bloqueado;
- O hash SHA-256 é calculado automaticamente no momento do registo;
- Na cadeia de custódia, cada hash encadeia com o hash do registo anterior (estrutura blockchain-like), tornando qualquer adulteração detectável.

4.3 Frontend

O frontend utiliza **HTML5/CSS3/JavaScript vanilla**, sem frameworks adicionais, por três razões:

1. Compatibilidade máxima em dispositivos móveis de campo (telemóveis de serviço da PSP, tablets ruggedizados);
2. Eliminação de dependências de compilação (sem Node.js, webpack, etc.) no servidor de produção;
3. Controlo total sobre o comportamento de acessibilidade e touch targets.

As páginas actualmente implementadas são:

- **Login** — autenticação JWT com feedback de erro;
- **Dashboard** — estatísticas e acções rápidas por perfil;
- **Ocorrências** — lista com pesquisa/paginação + mapa interactivo (Leaflet.js + OpenStreetMap);
- **Nova ocorrência** — formulário com GPS automático e reverse geocoding (Nominatim/OpenStreetMap);
- **Evidências** — lista com pesquisa, badges por tipo e paginação;
- **Nova evidência** — captura de foto (câmara/ficheiro), tipo selector, GPS automático;
- **Timeline de custódia** — visualização cronológica dos estados com hashes SHA-256 e modal de nova transição.

4.4 Testes

O projecto conta actualmente com **169 testes automatizados**, todos a passar:

- **14 testes de modelos** (User, Occurrence, Evidence, DigitalDevice, ChainOfCustody, AuditLog);
- **96 testes de API** (JWT em cookies HttpOnly, CSRF enforcement, CRUD por perfil, append-only, timeline, IDOR, imutabilidade, validação de entrada — IMEI/VIN/IMSI, ownership, throttling, lookup IMEIDB, agregação de `stats/dashboard`);
- **45 testes de frontend** (status 200, templates, elementos HTML, redireccionamento sem auth, timeline de custódia, mapa Leaflet);
- **14 testes de exportação PDF** (geração, endpoint REST, content-type, content-disposition, assinatura %PDF, 404 para evidência inexistente, PDF com e sem dispositivos digitais e cadeia de custódia).

Todos os testes utilizam uma base de dados SQLite em memória (`test_settings.py`), garantindo isolamento e velocidade.

5 Calendário e Planeamento

5.1 Progresso Face ao Plano Inicial

Semana	Planeado	Realizado	Desvio	Estado
Sem. 1 (17–21 mar)	Setup repositório, stack, proposta	Setup, proposta, envio sinopse	Nenhum	OK
Sem. 2 (24–28 mar)	Backend completo, API REST	Backend + API + Frontend base	Adiantado	OK
Sem. 3 (31 mar–6 abr)	Formulários frontend	Pausa Páscoa	Pausa programada	Pausa
Sem. 4 (7–13 abr)	Timeline, mapa	Formulários ocorrências/evidências	Reordenado	OK
Sem. 5 (14–20 abr)	PDF export	Timeline + Mapa Leaflet	Avanço	OK

Semana	Planeado	Realizado	Desvio	Estado
Sem. 6 (21–27 abr)	Relatório intercalar	PDF export + Testes PDF	Adiantado	OK
Sem. 7 (28 abr–4 mai)	Polish UX + segurança	CSP hardening, JWT cookies, taxonomia 18 tipos, lookup IMEI/VIN	Adiantado	OK
Sem. 8 (5–11 mai)	Submissão Fase 2	Compilação relatório intercalar com diagramas C4/ER	No prazo	Em curso
Sem. 9 (12–18 mai)	UX sweep mobile	Auto-tema entardecer, custody list responsivo, GPS por item, breadcrumb mobile	A iniciar	Planeado

Tabela 4: Progresso semanal face ao plano.

5.2 Próximas Tarefas

As tarefas prioritárias para as semanas seguintes são:

1. **Completar e submeter este relatório intercalar** (6 mai) — prazo eliminatório: preencher secções [FIG] com diagramas C4 e ER;
2. **Guião e dados de teste para demo** (28 abr–2 mai);
3. Avaliação de cobertura de testes (`pytest-cov`);
4. Testes de integração com a base de dados em produção (Neon.tech);
5. Botão de download PDF no frontend (página de detalhe de evidência).

6 Considerações sobre Ética e Privacidade

O ForensiQ processa dados pessoais (nome e número de crachá dos agentes) e dados potencialmente sensíveis (prova digital, fotografias de cenas de crime). O sistema foi desenhado com os seguintes princípios:

- **Minimização de dados:** apenas os metadados estritamente necessários para a cadeia de custódia são recolhidos;
- **Controlo de acesso:** os dados são acessíveis apenas a utilizadores autenticados com o perfil adequado (RBAC);
- **Auditabilidade:** toda a actividade sobre evidências é registada de forma imutável na cadeia de custódia;
- **Conformidade RGPD:** a imutabilidade dos registos de prova cria uma tensão com o direito

ao esquecimento (RGPD, art. 17.º). Esta tensão é resolvida pelo n.º 3, alínea e) do mesmo artigo, que exclui a obrigação de apagamento quando o tratamento seja necessário para a defesa de direitos em processos judiciais. O ForensiQ armazena apenas os metadados mínimos necessários (sem conteúdo pessoal das vítimas), pelo que o risco residual é considerado baixo.

O uso de inteligência artificial generativa no desenvolvimento do projecto será referenciado na secção de Referências, em conformidade com as orientações do orientador e com o princípio de honestidade académica.

7 Conclusão

O desenvolvimento do ForensiQ encontra-se em fase avançada e no caminho correcto para a entrega do MVP antes da Fase 2 (6 de maio de 2026).

Ao longo das primeiras seis semanas de trabalho, foram implementados e testados todos os critérios de aceitação do MVP, à excepção do botão de download PDF no frontend (a função de geração está concluída — falta apenas ligar o botão à API). O projecto conta com 94 testes automatizados, todos a passar, cobrindo modelos, API REST, páginas frontend e exportação PDF.

Os riscos principais para o prazo da Fase 2 são: (1) a necessidade de inserir as figuras C4/ER no relatório intercalar, que requerem trabalho manual de design, e (2) a avaliação formal de cobertura de testes (`pytest-cov`). Ambos são planeados para a Semana 6 (21–27 abr), deixando a Semana 7 como buffer para a submissão final e revisão.

A confiança na entrega do MVP funcional e da documentação formal no prazo é **alta**.

Referências

ISO/IEC. Information technology — security techniques — guidelines for identification, collection, acquisition and preservation of digital evidence. ISO/IEC 27037:2012, 2012. International Organization for Standardization.

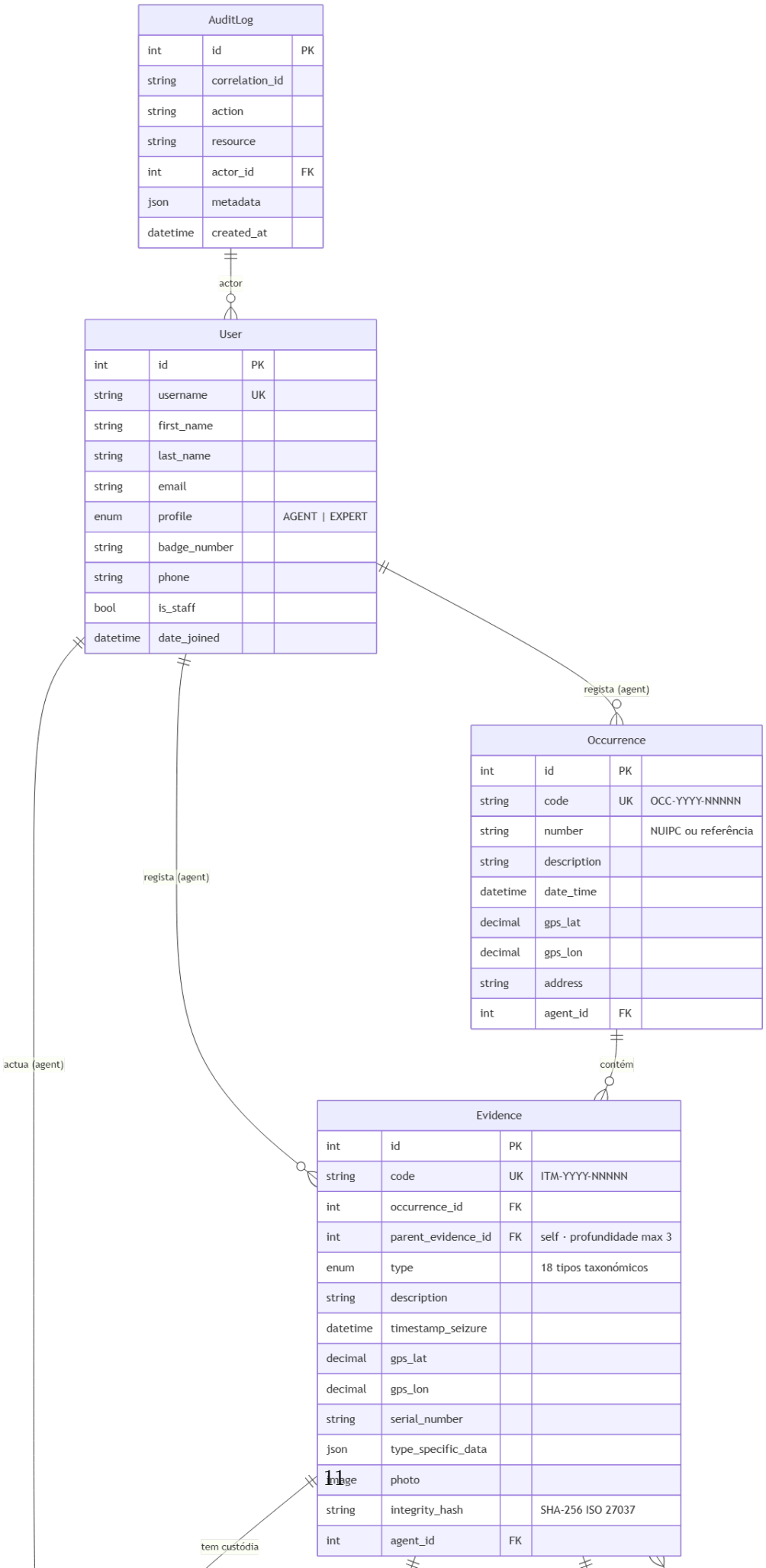
AuditLog
int id PK
string correlation_id
string action
string resource
int actor_id FK
json metadata
datetime created_at
actor
User
int id PK
string username UK
string first_name
string last_name
string email
enum profile AGENT | EXPERT
string badge_number
string phone
bool is_staff
datetime date_joined
regista (agent)
Occurrence
int id PK
string code UK OCC-YYYY-NNNNN
string number NUIPC ou referência
string description
datetime date_time
decimal gps_lat
decimal gps_lon
string address
int agent_id FK
contém
regista (agent)
actua (agent)
Evidence
int id PK
string code UK ITM-YYYY-NNNNN
int occurrence_id FK
int parent_evidence_id FK self · profundidade max 3
enum type 18 tipos taxonómicos
string description
datetime timestamp_seizure
decimal gps_lat
decimal gps_lon
string serial_number
json type_specific_data
image photo
string integrity_hash SHA-256 ISO 27037
int agent_id FK
tem custódia

Figura 4: Máquina de estados da cadeia de custódia.

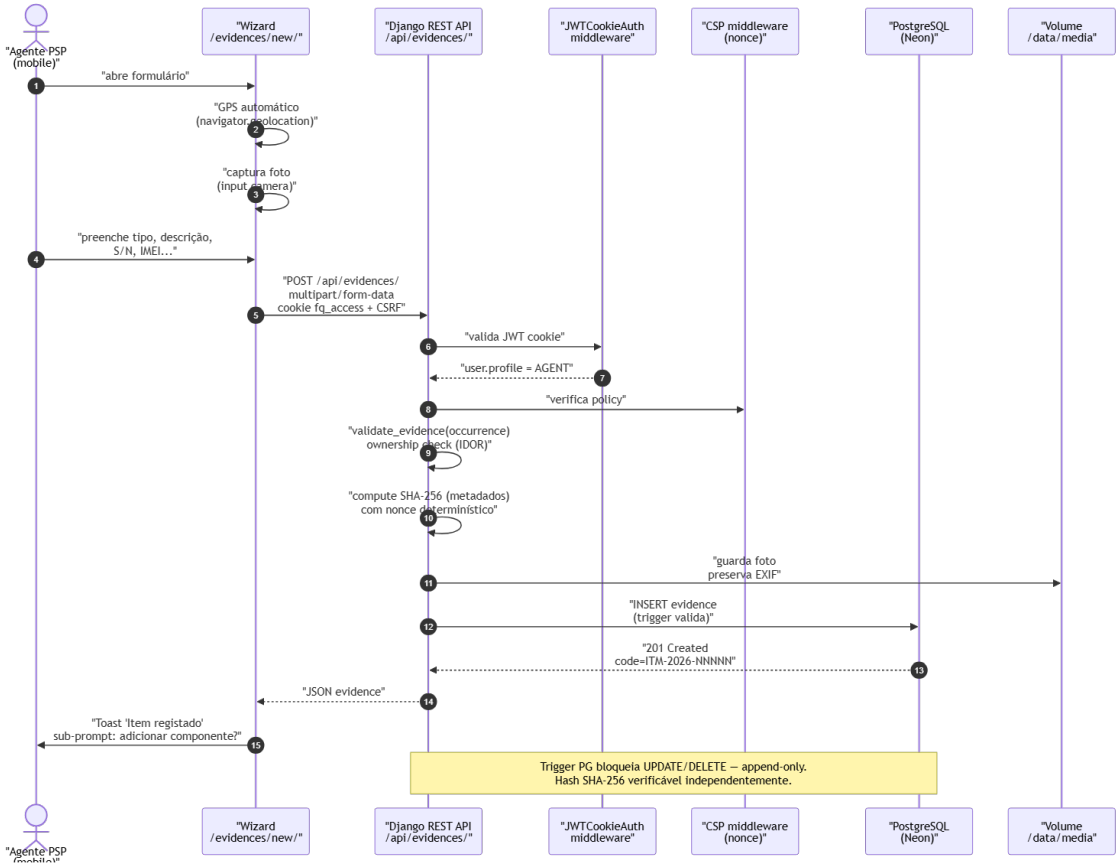

Figura 5: Sequência de criação de uma evidência por agente no terreno.